PostFinance

Zero Trust Konzept bei PostFinance

BatBern, 7 Nov. 2025

Ph. Halbeisen, Architektur PostFinance
M. Bouaaoud, Architektur PostFinance

Vorstellung

PostFinance

PostFinance ist ein führendes Schweizer Finanzinstitut für Privat- und Geschäftskunden, eine Tochtergesellschaft der Post.

Die Unternehmen hat mehr als 2.5 Millionen Kunden hauptsächlich in der Schweiz sowie zirka 4000 Mitarbeiter:innen.

Philippe Halbeisen

Zentral IT-Architekt bei PostFinance, verantwortlich für die Definition der gesamten Security-Architektur sowie die Begleitung der Security-betroffenen Vorhaben.

Email: philippe.halbeisen@postfinance.ch

Mustapha Bouaaoud

Leitet die IT-Architektur bei PostFinance und verantwortet zentrale Architekturthemen in den Bereichen Technologie, IT-Betrieb, Security, Integration, Cloud, Softwareentwicklung und KI.

Email: mustapha.bouaaoud@postfinance.ch

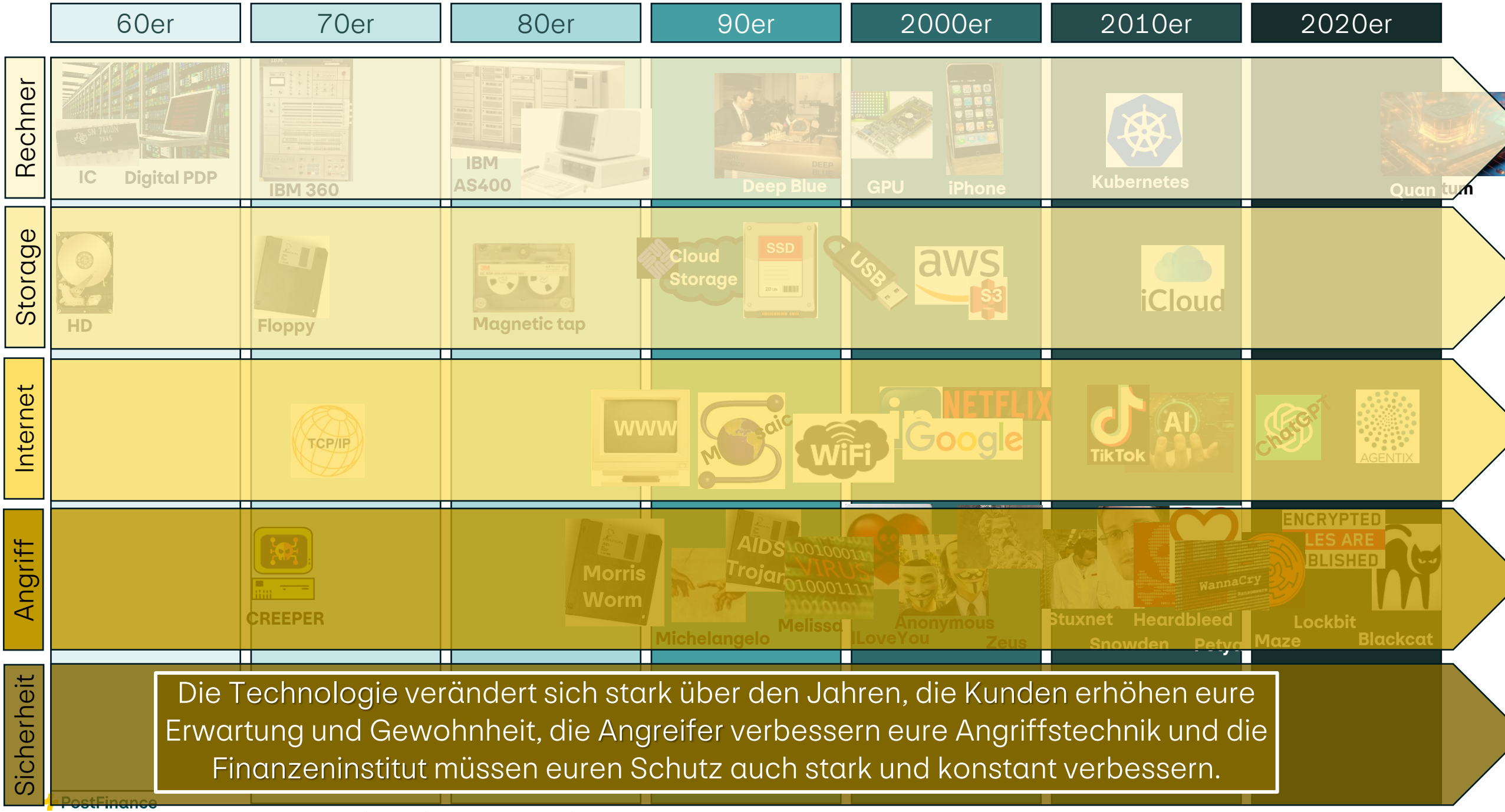
Inhaltsverzeichnis

1. Legacy Schutz bei der Banking-Bereich
2. Warum Zero Trust ist die richtige Lösung für die Zukunft?
3. Anforderungen & adressierten Risiken
4. Prinzipien der Zero Trust Architektur
5. Gesamtbild, Zielbild und Roadmap
6. Technische Sicht: Konzepte und Lösungsansatz
7. Wichtige Erkenntnisse

History

01

Legacy Schutz bei der Banking-Bereich



Die Technologie verändert sich stark über den Jahren, die Kunden erhöhen eure Erwartung und Gewohnheit, die Angreifer verbessern eure Angriffstechnik und die Finanzeninstitut müssen euren Schutz auch stark und konstant verbessern.

	60er	70er	80er	90er	2000er	2010er	2020er
Rechner							
Storage							
Internet		Isolation + Vault		Isolation + DMZ	Perimeter + Filtering	Cloud + Perimeter + Filtering	Zero Trust
Angriff							
Sicherheit							

Warum Zero Trust

02

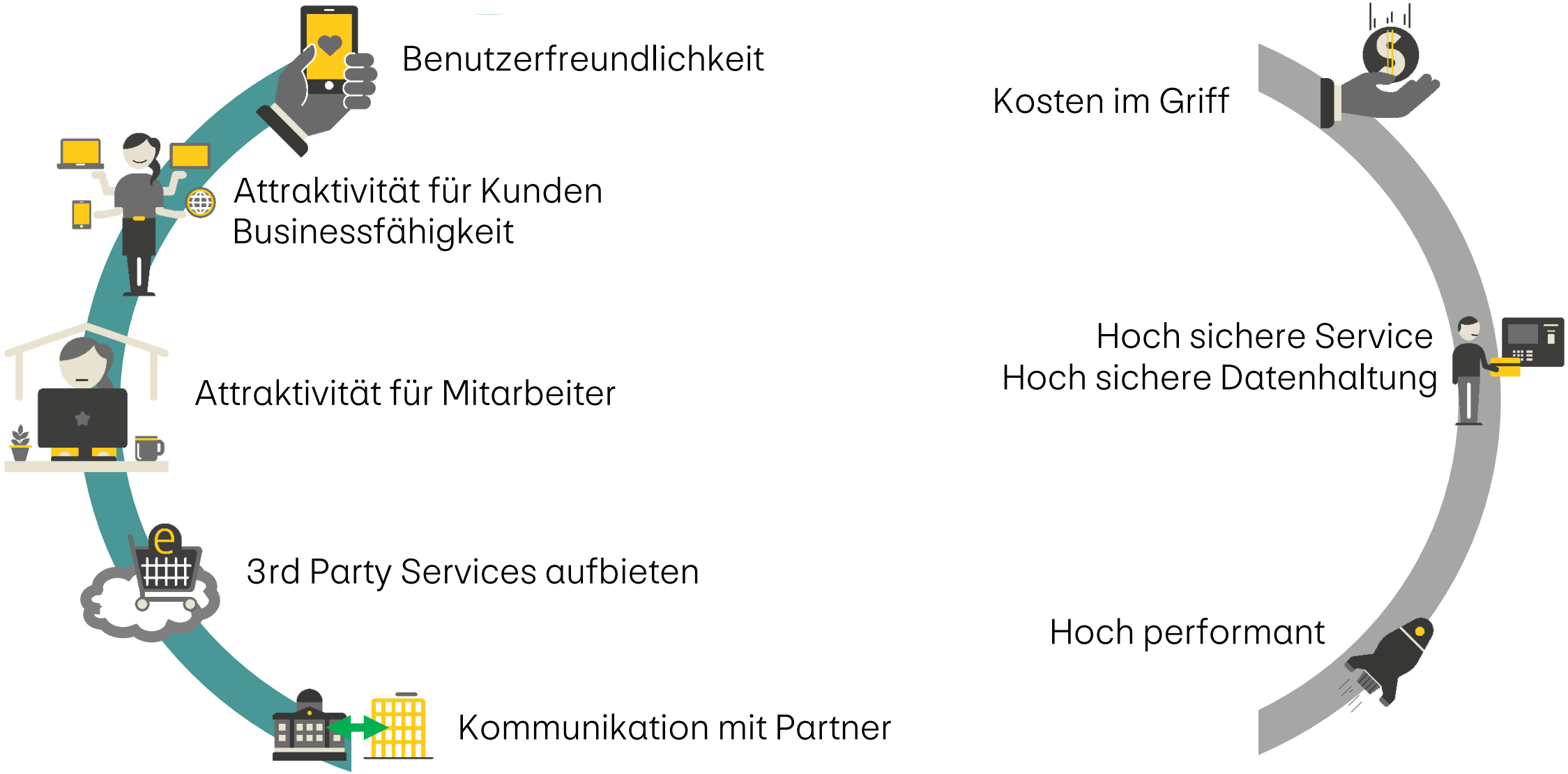
Warum Zero Trust ist die richtige Lösung für die Zukunft?

2 - Warum Zero Trust ist die richtige Lösung für die Zukunft?

Was muss die Unternehmen für die anderen tun?

Was muss die Unternehmen für sich sicherstellen?

2 - Warum Zero Trust ist die richtige Lösung für die Zukunft?



2 - Warum Zero Trust ist die richtige Lösung für die Zukunft?

Einfach

Multikanal

Unspürbar

Hoch sicher

Immer prüfen

Conditional, Risiko basiert

Zero Trust Konzept

Risiko basiert Zugriff aus allen Kanälen auf alle Firmendaten, mit expliziter Prüfung und Inspektion.

Anforderungen & adressierten Risiken

03

Zero Trust ist bei PostFinance hauptsächlich durch die Sicherheit gefordert

3 - Anforderungen & Adressierten Risiken

Risiken	Angriffsmethoden
Externe Angriff auf PF-Daten	Phishing, Brute Force, CSS, Komplex
Interne Angriff auf CID	Least Privilege Lücken, unsichere Design, Rechteausweitung
Ransomware	Lateral Movement, unsichere NW Design, zu grobe NW-Zonen

Bemerkung: Hier sind nur die wichtigsten Risiken neben viele anderen beschrieben

3 Anforderungen & Adressierten Risiken

Risiken	Anforderungen
Externe Angriff auf PF-Daten	Immer prüfen Immer MFA
Interne Angriff auf CID	Immer DLP, Malware Prüfung Kontext basierte Zugriff (UEBA, Device Posture, History, Label) Least Privilege Rollenkonzept
Ransomware	Microsegmentierung

Prinzipien

04

Prinzipien der Zero Trust Architektur

4 - Prinzipien der Zero Trust Architektur

Never Trust, always Verify

«Implizit Trust» durch «explizit Trust» wechseln

Conditional Access

Zugriff basiert auf Risiko und Kontext

Least Privilege

Zugriff auf PF-Daten auf das Minimal eingrenzen

Assume Bridge

Schutz innerhalb ein hostile Umgebung aufbauen inklusiv Mikrosegmentierung

4 - Prinzipien der Zero Trust Architektur

Prinzipien

Never Trust, always Verify

«Implizit Trust» durch «explizit Trust» wechseln

Conditional Access

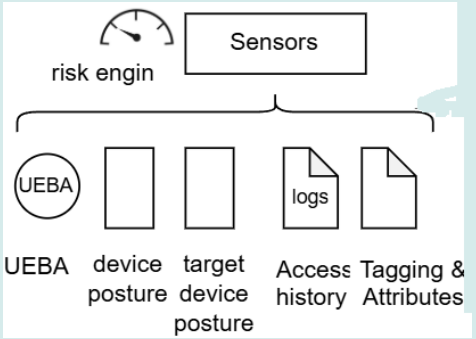
Zugriff basiert auf Risiko und Kontext

Konkret bei PF

VPN → **Dedizierte Kanal pro Asset**

IAM OIDC → **IAM OIDC** + **Jede Zugriff ist wieder geprüft**

IAM OIDC → **IAM OIDC** +



4 - Prinzipien der Zero Trust Architektur

Prinzipien

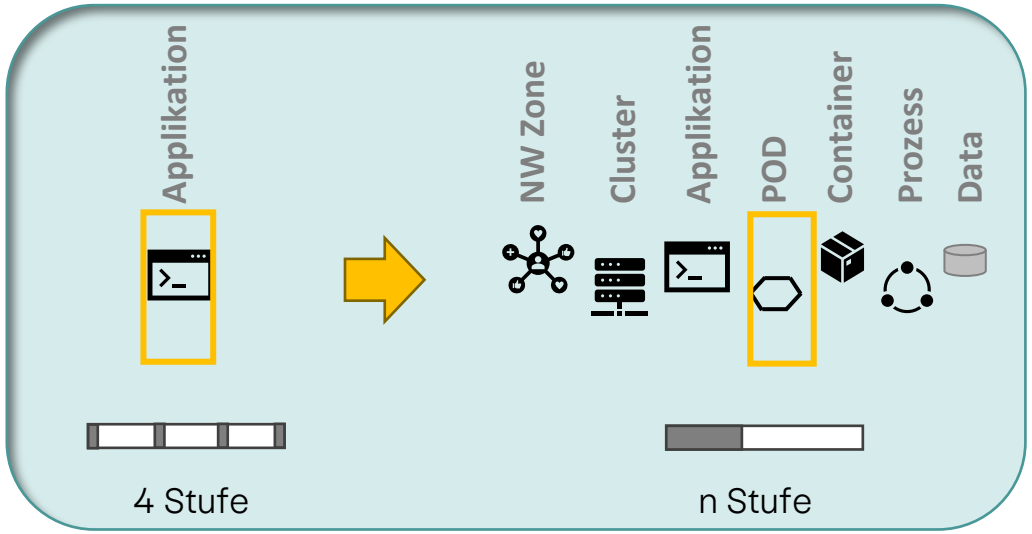
Least Privilege

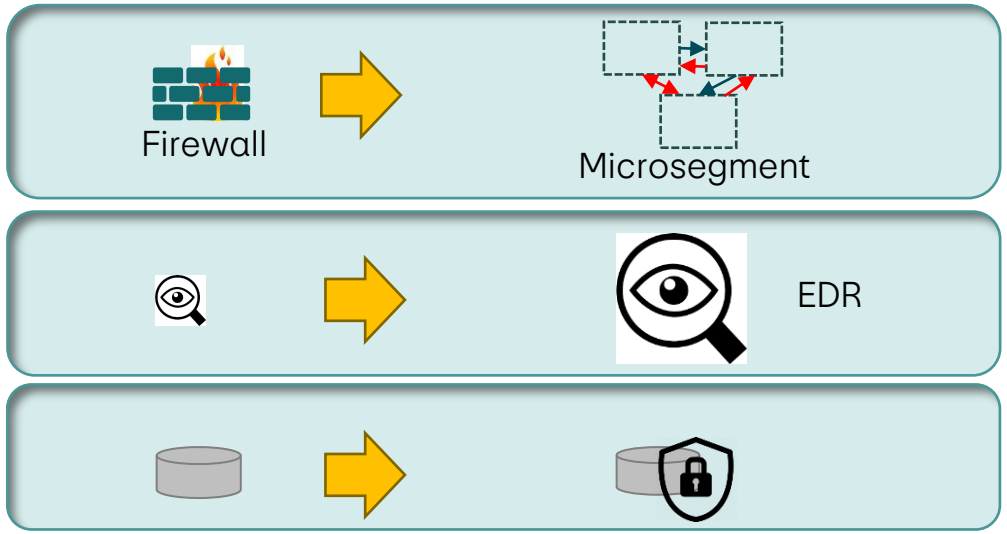
Zugriff auf PF-Daten auf das Minimal eingrenzen

Assume Bridge

Schutz innerhalb ein hostile Umgebung aufbauen inklusiv Mikrosegmentierung

Konkret bei PF



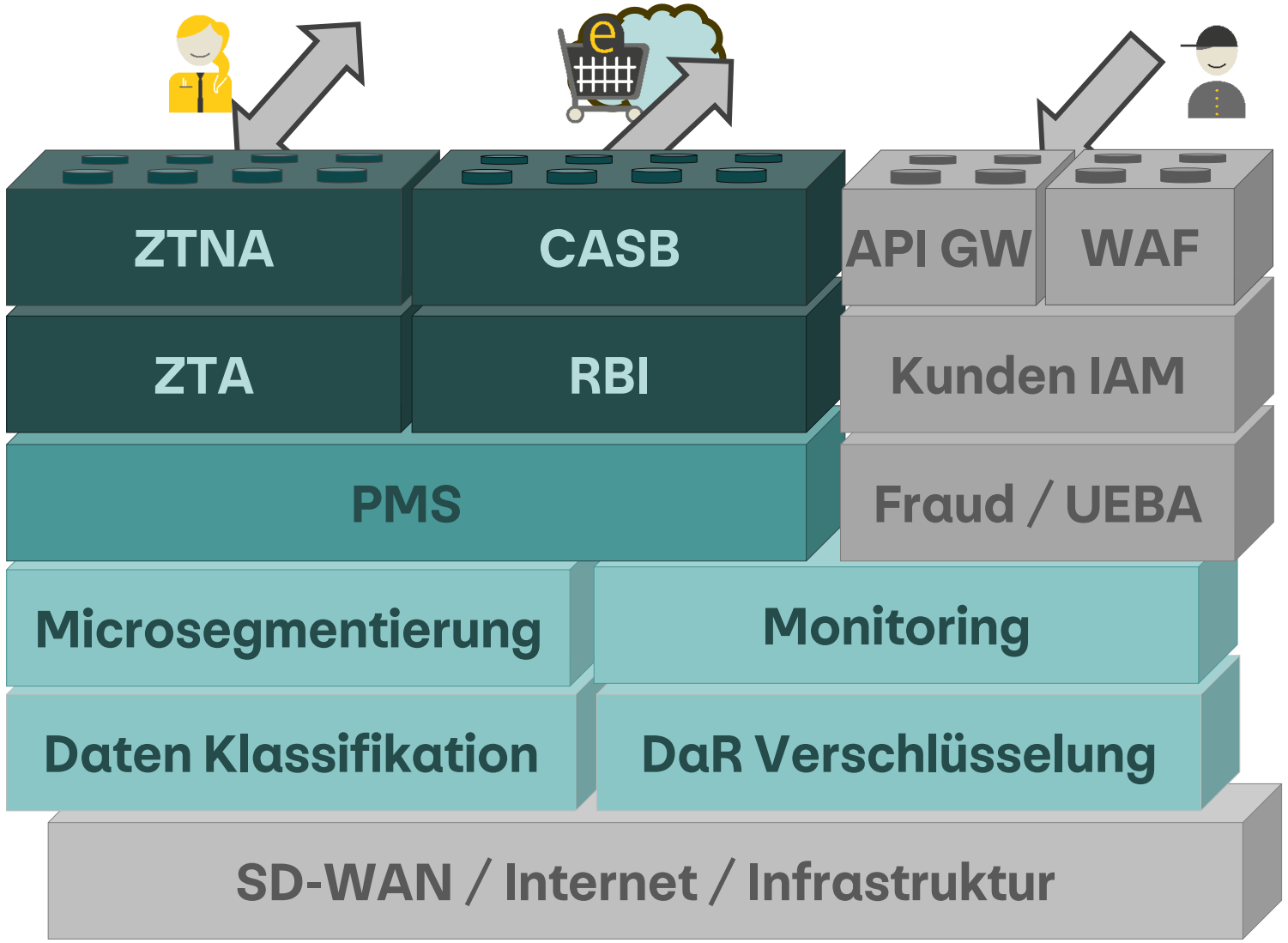


Zielbild

05

Gesamtbild, Zielbild und Roadmap

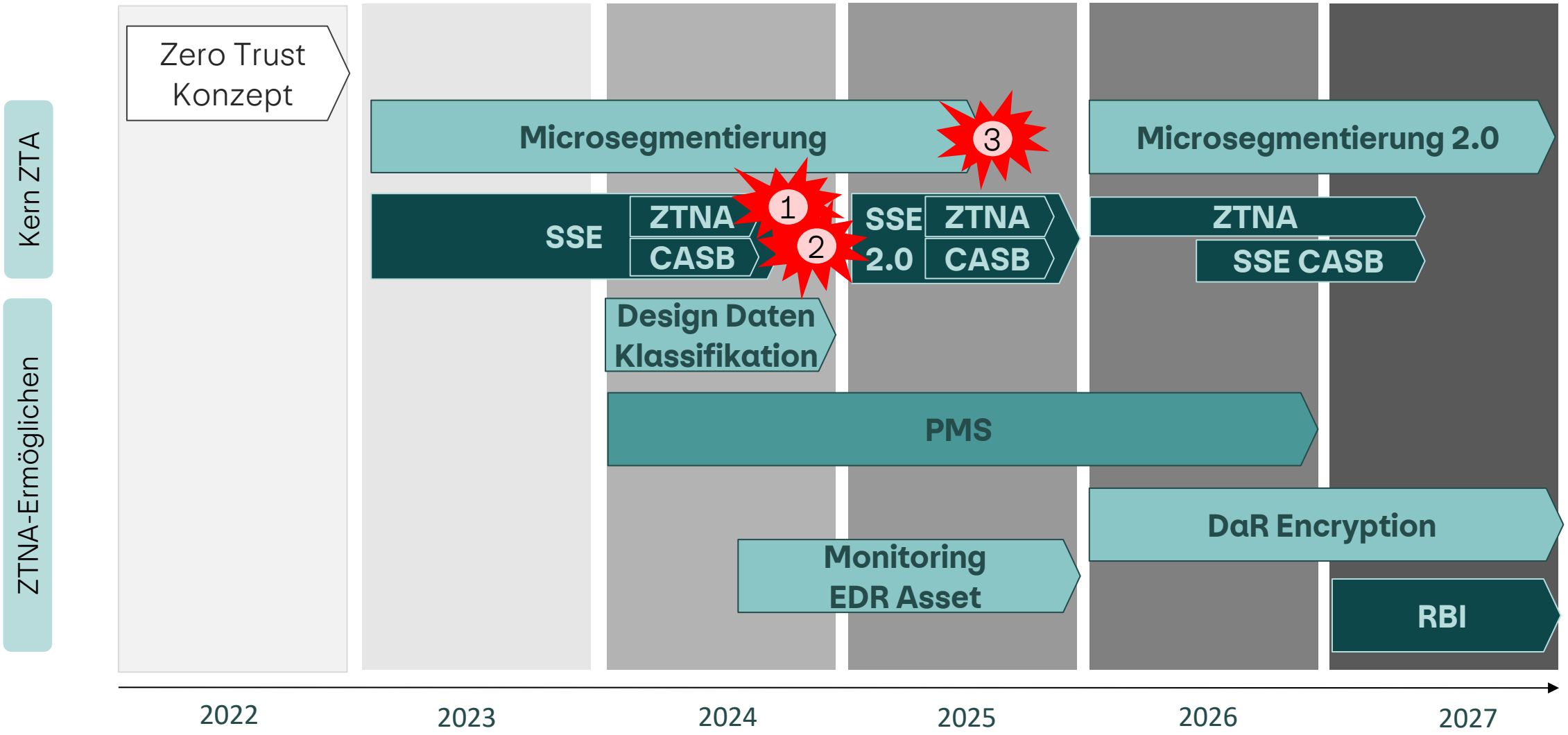
5 - Gesamtbild, Zielbild und Roadmap



- Kein gesamten Vendor Locking
- 4 grossen neuen Komponenten
  - Microsegmentierung
  - ZTNA
  - CASB
  - PMS
- Kunden nicht betroffen
- SSE (kein SASE)
- Iterative Verfahren

5 - Gesamtbild, Zielbild und Roadmap

1. POC nicht erfolgreich
2. IT braucht Verständnis
3. Produkt Limitation (K8s)

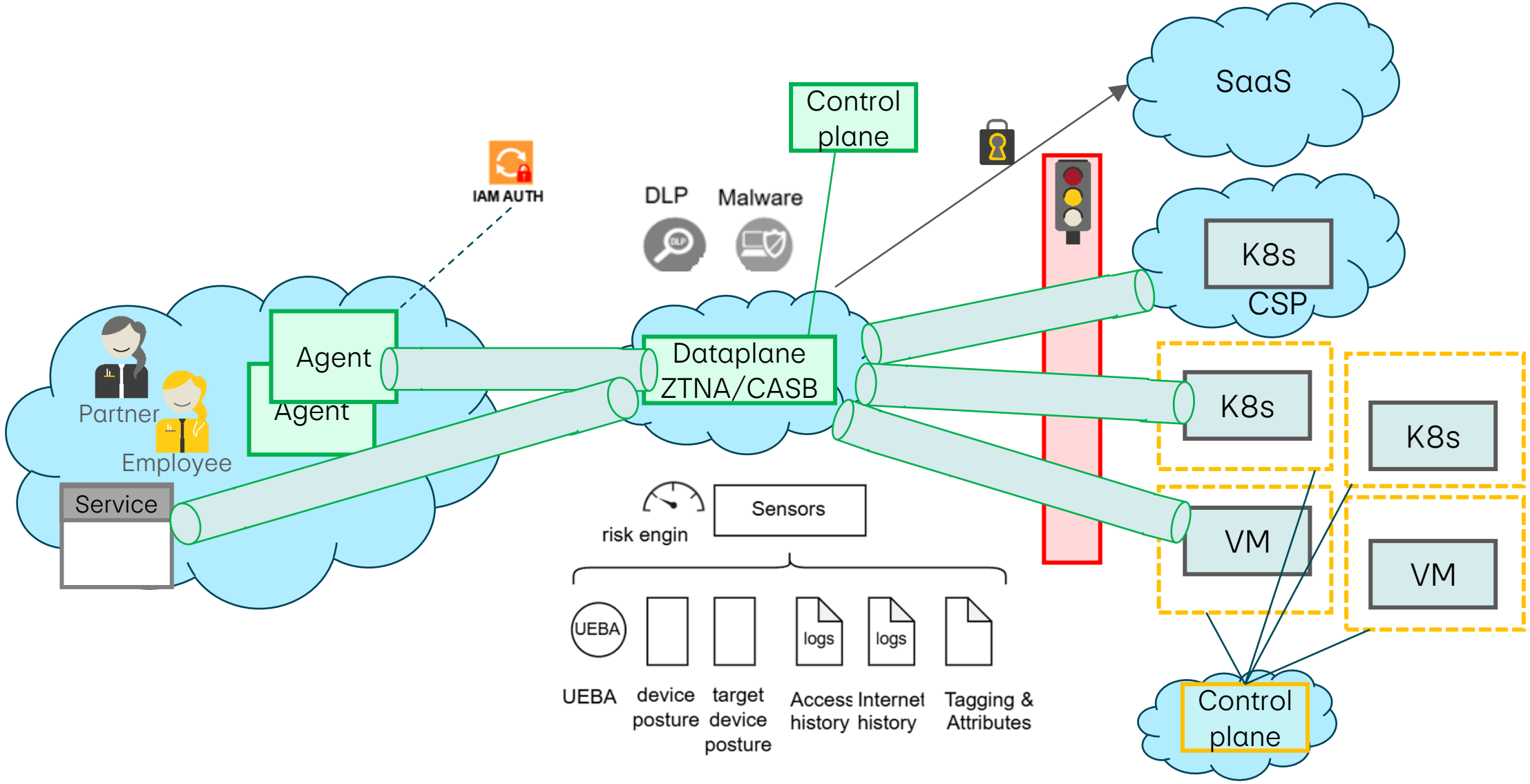


Technische Sicht

06

Konzepte und Lösungsansatz

6 - Technische Sicht: Konzepte und Lösungsansatz



Wichtige Erkenntnisse

07

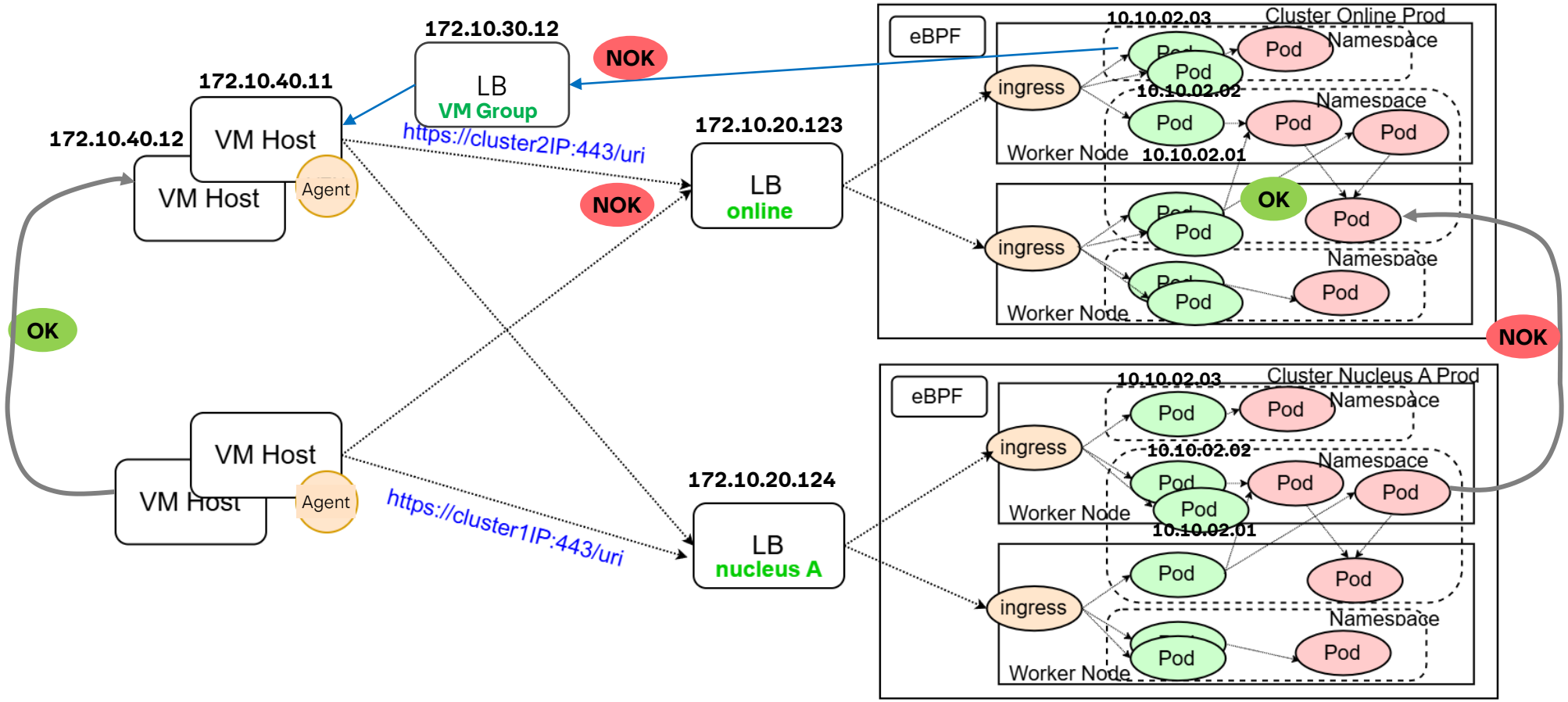
7 - Wichtige Erkenntnisse - Generisch

- PF-Sicherheitsziele können durch Zero Trust-Lösungen ermöglicht werden
- Die Komplexität der Lösungen führen schnell zu einem «Vendor Lock-in»
- Die ideale Lösung ist komplex. Man muss Kompromisse akzeptieren.
- Die Haupt-Bremse zu einer erfolgreichen Zero Trust-Lösung ist die eigene Organisation

7 - Wichtige Erkenntnisse - Technologie

- Die Technologie bewegt sich schneller als bei anderen Technologien
- Die Roadmap muss deswegen jede 6 Monaten adaptiert werden
- Die Ziele und Roadmap sind aber Key für die Implementation (nicht das Produkt selbst)
- Die Implementation mit zu viele Technologieprodukt ist zu teuer und nicht verwaltbar
- Die Implementation mit zu wenig Technologieprodukt bringt eine Vendor Lock-in Risiko
- Wichtig: Am Ende braucht man ein grosses Vertrauen auf dem gewählten Hersteller

7 - Wichtige Erkenntnisse – Problemen mit Microsegmentierung



7 - Wichtige Erkenntnisse – Problemen mit SSE POC

Gute Ergebnis

- Risiko basierte Zugriff auf Asset funktioniert bei ZTNA optimal
- Kontext basierte Zugriff funktioniert bei ZTNA und CASB sehr gut
- DLP und Malware Prüfung klar bei CASB aber auch bei ZTNA effizient
- Die Lösung unterstützt die PF-Infrastruktur
- Data Plane kann auch onPrem eingesetzt werden

Schlechte Ergebnis

- Technische Identität ist weniger oder schlecht unterstützt im vergleich zu Personen
- Wenig Produkte unterstützen eine E2E Lösung bis zum Ziel-Service
- Kubernetes nicht vollständig unterstützt
- Daten sind teilweise in EU

7 - Wichtige Erkenntnisse – Problemen innerhalb Organisation

Problems

- Zero Trust Initiative ist von Security getriggert. Andere OEs bremsen weil sie eure eigenen Vorhaben pushen wollen.
- Die meisten OE sind für die Zero Trust-Veränderungen noch nicht bereit
- Zero Trust ist komplex und wird nicht von jedem Mitarbeiter verstanden und akzeptiert.

Empfehlung

- Zero Trust Initiative soll Top Down von der Top Führung getriggert und stark gepusht
- Zusätzliche Ressourcen sind initiale benötigt, auch wenn es mittelfristig weniger brauchen wird.
- Es braucht sehr viel Workshops, Knowledge Verteilung und vielleicht Schulung.

Danke für eure Aufmerksamkeit

Fragen?

PostFinance